



الاسم المسجل : شركة الوثيقة الماسية لوساطة التأمين
المركز الرئيسي : طريق النمامة , الربيع , الرياض
مسؤول المستند : مشرف تقنية المعلومات

ادارة المستند

مراقبة المستند :

أعدها	الوظيفة	التاريخ	التوقيع
نوف الرعوي	مسؤول الجودة والتطوير	29/01/2025	
راجعها	الوظيفة	التاريخ	التوقيع
شادن العتيبي	إدارة الجودة والتطوير	02/02/2025	
اعتمدها مبدئياً	الوظيفة	التاريخ	التوقيع
جيثن فيركي	مشرف تقنية المعلومات	13/03/2025	
اعتمدها نهائياً	الوظيفة	التاريخ	التوقيع
بدر الشايع	العضو المنتدب	13/03/2025	

تاريخ المراجعة:

رقم الاصدار	تاريخ التنفيذ	موقع التغيير	وصف التغيير

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بشركة الوثيقة الماسية (دايموند) ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءاً منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيد في أي حالة من هذا المستند.

المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.



DO NOT COPY

جدول المحتويات

إدارة المستند

القسم الأول- إجراءات التشغيل القياسية	إدارة الجودة والتطوير
1. مقدمة	1.1 الغرض
1.2 الفئات المستهدفة	1.3 التعريفات
1.4 مراقبة المستند	1.5 الملكية والمراجعة
1.6 تغييرات على إجراءات التشغيل القياسية	1.7 تطبيقات تقنية المعلومات
1.8 الأنشطة الرئيسية	1.9 لمحة عامة عن الإدارة
1.10 الأدوار والمسؤوليات	1.10.1 إدارة الهوية والوصول
1.10.1.1 إنشاء الحسابات	1.10.1.2 مابعد إنشاء الحسابات
1.10.1.3 مابعد حذف الحسابات	1.10.2 اختبار الأنظمة
1.10.3 الاستجابة للحوادث	1.10.3.1 آلية الاستجابة للحوادث
1.11 تفويض الصلاحية	2. التقارير الداخلية
2.1 الخلفية	2.2 العملية
3. اللوائح السارية	4. التوظيف والتدريب
5. حفظ السجلات	5.1 السجلات الإلكترونية
5.1.1 استعادة المعلومات أو نقلها من جهاز إلى آخر	5.1.2 خطة الطوارئ لتجنب فشل عملية النسخ الاحتياطي
6. المراجع	



القسم الأول- إجراءات التشغيل القياسية

1 مقدمة:

تثق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "دايموند") في أن الهدف من إجراءات التشغيل القياسية الخاصة بها هو تمكين المؤسسة من تحقيق أهدافها الاستراتيجية من خلال تطبيقات أمنية قوية تمكن الشركة من حماية بياناتها وأصولها الرقمية لضمان استمرارية أعمالها والحفاظ على سمعتها تحدد إجراءات التشغيل القياسية الأدوار والمسؤوليات والعمليات الخاصة بالأفراد المشاركين في أنشطة الدعم السيبراني ووضع الضوابط الرئيسية ضمن الأنشطة المنفذة من قسم الأمن السيبراني لتعزيز الهيكل العام للشركة.

1.1 الغرض:

الهدف من إجراءات التشغيل القياسية هي:

- حماية الأصول المعلوماتية التي تشمل حماية البيانات والأنظمة والتطبيقات من التهديدات السيبرانية.
- ضمان استمرارية الأعمال من خلال حماية أنظمة الكمبيوتر والشبكات من السرقة أو التلف أو الوصول غير المصرح به إلى البيانات التي تحتفظ بها.
- الحفاظ على سمعة الشركة فحماية البيانات يحافظ على سرية معلومات العملاء الذي بدوره يزيد ثقة العميل اتجاه الشركة.

1.2 الفئات المستهدفة:

فيما يلي الفئات الموجه إليها هذا المستند:

- قسم الأمن السيبراني.
- الموظفين في قسم الأمن السيبراني.

1.3 التعريفات:

فيما يلي بعض الإختصارات والتعريفات التي تتعلق بإجراءات:

1.3.1 مصطلحات سيبرانية:

- البرامج الضارة **Malware**: برامج خبيثة مصممة لإتلاف أو تعطيل أنظمة الكمبيوتر. الأمثلة: الفيروسات والديدان وبرامج الفدية وبرامج التجسس.
- هجوم إلكتروني **Cyberattack**: محاولة لاستغلال نقاط الضعف في نظام أو شبكة للوصول غير المصرح به إلى البيانات أو تعطيل الخدمات.
- التصيد الاحتيالي **Phishing**: نوع من الهجمات الإلكترونية التي تحاول خداع المستخدمين للكشف عن معلومات حساسة، مثل كلمات المرور وأرقام بطاقات الائتمان، غالبًا عن طريق التخلي ككيان جدير بالثقة في الاتصالات الإلكترونية.
- تعطيل خدمة الرفض **DoS/DDoS**: محاولة تعطيل الخدمة أو موقع الويب عن طريق إغراقه بكمية كبيرة من حركة المرور.
- هجوم الوسيط **Man-in-the-middle attack**: فقد الاتصال بين طرفين وسرقة أو تغيير البيانات المتبادلة.
- الاختراق **Hacking**: محاولة الوصول إلى نظام أو شبكة غير مصرح به.
- الثغرات الأمنية **Vulnerabilities**: خلل في نظام الكمبيوتر أو التطبيق أو الشبكة التي يمكن أن يستغلها المهاجم للوصول غير المصرح به إلى البيانات أو الأنظمة.

1.3.2 مفاهيم سيبرانية:

- الأمن السيبراني **Cybersecurity** مجموعة تدابير وتقنيات مستخدمة للإلكترونيات والشبكات والبيانات الأمنية من البنوك السيبرانية.
- جدار الحماية **Firewall**: نظام أمان الشبكة الذي يراقب ويتحكم في حركة المرور الواردة والصادرة على الشبكة بناءً على قواعد أمان محددة مسبقًا.
- التشفير **Encryption**: تحويل البيانات إلى تنسيق غير قابل للقراءة لحمايتها من الوصول غير المصرح به.
- المصادقة **Authentication**: التحقق من هوية المستخدم أو الجهاز.
- تحديد التفويض **Authorization**: الصلاحيات التي تبرزها المستخدم أو الجهاز.
- النسخ الاحتياطي **Backup**: إنشاء نسخة من البيانات لاستعادتها في حالتها القوية أو تلفها.
- استمرارية الأعمال **Business Continuity**: خطط وإجراءات تهدف إلى ضمان استمرار العمل في حالة وقوع كارثة أو هجوم إلكتروني.
- التعافي من الكوارث **Disaster Recovery**: خطط وإجراءات تهدف إلى استعادة الأنظمة والبيانات في حالة وقوع كارثة.

1.3.3 مصطلحات ادارية:

- CEO : الرئيس التنفيذي Chief Executive Officer
- HRM : مدير الموارد البشرية Human Resources Manager
- ITM : مدير تقنية المعلومات Information Technology Manager
- TM : المدير الفني Technical Manager
- FM : المدير المالي Finance Manager
- LCM : مدير الشؤون القانونية والامتثال Legal and Compliance Manager
- OM : مدير العمليات Operation Manager
- SMD : رئيس إدارة المبيعات والتسويق Sales and Marketing Director
- QDM : مدير إدارة الجودة والتطوير Quality and Development Manager

1.3 مراقبة المستند:

- تعتبر محتويات إجراءات التشغيل القياسية هذه سرية والهدف منها فقط هو للاستخدام الداخلي في الشركة. يجب الاحتفاظ دائما بإجراءات التشغيل القياسية هذه في مكان آمن ولا يجب نسخها أو كشفها الى أطراف ثالثة.
- سوف يتم توزيع هذا المستند كاملا أو جزءا منه فقط كما هو معتمد من مدير إدارة الجودة والتطوير.
- يجب قراءة الإقسام ذات العلاقة من إجراءات التشغيل القياسية من قبل الموظفين المعنيين في الشركة بما يضمن الالتزام بإجراءات قسم الأمن السيبراني.
- سوف تظل نسخة ورقية في عهدة إدارة الجودة والتطوير.

1.4 الملكية والمراجعة:

- بينما يستخدم هذا المستند بمثابة إرشاد وتوجيه لإدارة عمليات قسم الأمن السيبراني،، يجدر ملاحظة أنه:
- يمنح العضو المنتدب الإعتماد النهائي لإجراءات التشغيل القياسية.
 - يراقب مجلس الادارة حوكمة اجراءات التشغيل القياسية، ويتأكد من الطابع الرسمي على اجراءات التشغيل القياسية وتحديثها سنويا.
 - تكون إدارة المستند تحت الإشراف المباشر لمشرف إدارة تقنية المعلومات.
 - تضمن إدارة الجودة والتطوير وإدارة الإلتزام أن الرقابة المنفذة مناسبة وكافية طبقا لإجراءات قسم الأمن السيبراني



1.5 تغييرات على إجراءات التشغيل القياسية:

يتم إجراء تعديلات عند الضرورة على إجراء التشغيل القياسي هذا سنوياً، ومع هذا في ظل الظروف غير العادية التي تشمل الظروف الموضحة أدناه يمكن أن تحدد التعديل عند الطلب. تكون التغييرات على المستند عادة من الطبيعة التالية:

- التغييرات في القوانين واللوائح.
- التغيير في وظيفة وأنشطة الشركة.
- التغيير في إجراءات العمل.
- التغيير في الهيكل التنظيمي لشركة دايمود.
- التغيير في الدور والواجبات والوصف الوظيفي.
- التغيير في مجموعة المخاطر التي تعمل الشركة فيها.
- أي تغيير آخر في اللوائح أو الاستراتيجية أو التشغيل.

1.6 تطبيقات تقنية المعلومات:

يتم استخدام أنظمة كشف التسلل لاكتشاف الهجمات السيبرانية كما تستخدم أدوات وتثبيتات الحماية وبرامج مكافحة الفيروسات .

1.7 الأنشطة الرئيسية:

تُعرف بدقة الخطوات والمهام ضمن إدارة الأمن السيبراني، لضمان سير العمل بسلاسة وكفاءة من خلال توفير الدعم السيبراني لجميع إدارات الشركة



1.9 ملحة عامة عن الإدارة:

يبين الشكل التالي الهيكل الحالي لقسم (الأمن السيبراني):



1.10 الأدوار والمسؤوليات :

المسؤولية	النشاط	العملية الفرعية
مسؤول الأمن السيبراني.	تعتمد الشركة استراتيجية متكاملة للأمن السيبراني تشمل: - تقييم دوري للمخاطر الأمنية. - استخدام جدران الحماية والأنظمة المتقدمة للكشف عن التهديدات. - تطبيق تقنيات التشفير لحماية البيانات أثناء النقل والتخزين.	إدارة المخاطر
مسؤول الأمن السيبراني.	الامتثال للوائح الهيئة الوطنية للأمن السيبراني (NCA) وهيئة التأمين (AI): - تطبيق معايير AI Cybersecurity Framework لضمان الامتثال الكامل لقطاع التأمين. - تبني أفضل الممارسات العالمية مثل ISO 27001 و NIST Cybersecurity Framework. - تنفيذ برنامج تقييم مخاطر الأمن السيبراني بشكل دوري للكشف عن الثغرات وتقليل المخاطر. إدارة مخاطر الجهات الخارجية (Third-Party Risk Management - TPRM): - وضع متطلبات أمنية صارمة لمزودي الخدمات التقنية مثل أنظمة السحابة وموفري الخدمات المدارة. - إجراء تدقيق سنوي لأمن البيانات للموردين لضمان توافقهم مع سياسات الشركة.	الامتثال التنظيمي وتقوية الامتثال السيبراني
مسؤول الأمن السيبراني.	- الالتزام بمتطلبات AI للإبلاغ عن الحوادث السيبرانية خلال الفترات الزمنية المحددة. - الاحتفاظ بسجلات الحوادث الإلكترونية للتدقيق والامتثال التنظيمي.	التقارير الأمنية والامتثال
مسؤول الأمن السيبراني.	- استخدام الأدوات اللازمة لإدارة كلمات المرور وتحديد الصلاحيات لمن يمكنه الوصول إلى المعلومات - تحديد مستويات الصلاحيات بناءً على الأدوار الوظيفية، لضمان عدم وصول المستخدمين غير المخولين إلى المعلومات الحساسة.	مصفوفة الصلاحيات والتحكم بالوصول



المسؤولية	النشاط	العملية الفرعية
مسؤول الأمن السيبراني.	تلتزم الشركة بتطبيق سياسات صارمة لحماية بيانات العملاء وفقاً للأنظمة المعمول بها مثل اللائحة العامة لحماية البيانات (GDPR) وقانون حماية البيانات الشخصية السعودي (PDPL)، بما يشمل: - تحديد آليات تخزين وتأمين البيانات الحساسة. - التحكم في الوصول إلى البيانات بناءً على الأدوار والصلاحيات. - وضع إجراءات لمراقبة الاستخدام ومنع التسريبات.	حماية البيانات والخصوصية
مسؤول الأمن السيبراني.	- استخدام أنظمة الكشف عن التهديدات المستندة إلى الذكاء الاصطناعي (AI-Driven SIEM) لمراقبة الشبكة واكتشاف أي أنشطة غير طبيعية. - تنفيذ أنظمة الاستجابة الأمنية التلقائية (Security Orchestration, Automation, and Response - SOAR) لمكافحة الهجمات بشكل فوري	الحماية من التهديدات السيبرانية باستخدام الذكاء الاصطناعي (AI) والتحليلات الأمنية
مسؤول الأمن السيبراني.	- رصد التسريبات المحتملة لمعلومات الشركة أو بيانات العملاء على الإنترنت المظلم. - الاشتراك في قواعد بيانات استخبارات التهديدات السيبرانية لتحديث الدفاعات السيبرانية.	مراقبة الإنترنت العميق والدارك ويب (Dark Web Monitoring)
مسؤول الأمن السيبراني.	- تطبيق أنظمة الحماية المتقدمة لنقاط النهاية (EDR/XDR) لمنع هجمات البرمجيات الخبيثة (Malware) والهجمات المتقدمة المستمرة (APT). - تنفيذ جدران حماية من الجيل التالي (NGFW) لمراقبة الأنشطة المشبوهة ومنع التسلسل.	الحماية المتقدمة لنقاط النهاية والخوادم
	- مراقبة سلوك المستخدمين على الشبكة باستخدام User Behavior Analytics (UBA). - تنفيذ سياسات صارمة للوصول إلى البيانات الحساسة ومنع نقلها خارج الشركة.	حماية الشركة من التهديدات الداخلية

المسؤولية	النشاط	العملية الفرعية
مسؤول الأمن السيبراني.	- استخدام أنظمة الكشف عن التهديدات المستندة إلى الذكاء الاصطناعي (AI-Driven SIEM) لمراقبة الشبكة واكتشاف أي أنشطة غير طبيعية. - تنفيذ أنظمة الاستجابة الأمنية التلقائية (Security Orchestration, Automation, and Response - SOAR) لمكافحة الهجمات بشكل فوري.	الحماية من التهديدات السيبرانية باستخدام الذكاء الاصطناعي (AI) والتحليلات الأمنية
مسؤول الأمن السيبراني.	يتم فيه مراقبة الأنظمة والشبكات بشكل مستمر للكشف عن أي نشاط مشبوه.	مراقبة الأنظمة والشبكات
مسؤول الأمن السيبراني.	تساعد في تحديد نقاط الضعف في أنظمة الشركة وتقييم المخاطر المحتملة.	تحديد المخاطر
مسؤول الأمن السيبراني.	حماية البيانات من الاختراقات والفايروسات عن طريق استخدام برامج مكافحة الفايروسات.	ضمان أمن المعلومات
مسؤول الأمن السيبراني.	- توعية الموظفين حول مخاطر الأمن السيبراني وتثقيفهم حول أفضل الممارسات الأمنية. - تنظيم اختبارات تصيد احتيالي (Phishing Simulations) شهرية لتقييم قدرة الموظفين على كشف الاحتيال. - إرسال تنبيهات دورية عن أحدث التهديدات السيبرانية عبر البريد الإلكتروني.	التوعية الأمنية
مسؤول الأمن السيبراني.	يتم نسخ وأرشفة معلومات الحواسيب حتى يتمكن استعادتها في حال فقدان البيانات الأصلية أو العبث بها.	النسخ الاحتياطي
مسؤول الأمن السيبراني.	- حفظ النسخ الاحتياطية بشكل منتظم واستعادتها عند الحاجة. - وجود خطة استجابة للهجمات الإلكترونية مثل هجمات الفدية (Ransomware). - وضع آليات واضحة لإدارة الأزمات والطوارئ.	خطة استمرارية الأعمال والتعافي من الكوارث
مسؤول الأمن السيبراني.	- محاكاة هجمات إلكترونية معقدة مثل Advanced Persistent Threats (APT). - تقييم مدى جاهزية الفريق السيبراني للتعامل مع الاختراقات الأمنية.	إجراء اختبارات هجومية دورية (Red Team vs. Blue Team Drills)

المسؤولية	النشاط	العملية الفرعية
مسؤول الأمن السيبراني.	تطوير استراتيجية المرونة السيبرانية (Cyber Resilience Strategy): - تنفيذ خطة استجابة ضد برامج الفدية (Ransomware Response Plan) لاستعادة البيانات بسرعة. - فرض تخزين بيانات غير قابلة للتغيير (Immutable Backup Storage) لحماية النسخ الاحتياطية.	تعزيز استجابة الحوادث وخطط استمرارية الأعمال
مسؤول الأمن السيبراني.	تطبيق نهج "عدم الثقة" (Zero Trust Architecture - ZTA): - تنفيذ سياسات المصادقة المستمرة لكل محاولة وصول، حتى من داخل الشبكة الداخلية. - فرض سياسات الصلاحيات الأقل امتيازاً (Least Privilege Access Control - LPAC).	التقنيات المتقدمة لتعزيز الأمن السيبراني
مسؤول الأمن السيبراني.	تأمين بيئات الحوسبة السحابية - تنفيذ سياسات أمن السحابة (Cloud Security Policies) وفق معايير CSPM - Cloud Security Posture Management. - فرض تشفير بيانات التخزين السحابي باستخدام بروتوكولات AES-256	الأمن السيبراني في البنية التحتية السحابية

1.10.1 إدارة الهوية والوصول:

ويقصد بها إدارة هويات المستخدمين والتحكم في الوصول للأنظمة والبيانات وفقاً للصلاحيات المناسبة فقط.

1.10.1.1 إنشاء الحسابات:

- 1- تحديد المستخدمين: تحديد الموظفين أو المستخدمين الذين يحتاجون إلى حسابات على النظام.
- 2- تحديد الصلاحيات: تحديد مستوى الوصول والصلاحيات التي يحتاجها كل مستخدم بناءً على دوره ومسؤولياته.
- 3- تعبئة النماذج: ملء النماذج المطلوبة لإنشاء الحساب، والتي تتضمن هذه المعلومات المستخدم وبيانات الاتصال.
- الاسم.
- عنوان البريد الإلكتروني (إذا كان حساباً من نوع معين).
- كلمة المرور.
- تاريخ الميلاد (في بعض الحالات).
- معلومات إضافية أخرى (حسب نوع الحساب).
- 4- الموافقة: الحصول على موافقة من المسؤولين المعنيين قبل إنشاء الحساب.
- 5- إنشاء الحساب: إنشاء الحساب على النظام وتعيين كلمة مرور أولية.
- 6- تزويد المستخدم بالمعلومات: تزويد المستخدم بمعلومات تسجيل الدخول واسم المستخدم وكلمة المرور الأولية.
- إدارة الحسابات.

1.10.1.2 ما بعد إنشاء الحسابات:

- 1- تغيير كلمات المرور: إلزام المستخدمين بتغيير كلمات المرور بشكل دوري للحفاظ على الأمان.
- 2- تحديث المعلومات: تحديث معلومات المستخدمين بشكل دوري مثل بيانات الإتصال والمسمى الوظيفي.
- 3- تعديل الصلاحيات: تعديل صلاحيات المستخدمين حسب الحاجة، مثل إضافة أو إزالة الوصول إلى موارد معينة.
- 4- تعطيل الحسابات: تعطيل حسابات المستخدمين الذين يتكون العمل أو ينتقلون إلى إدارات أخرى.
- 5- مراقبة الحسابات: مراقبة نشاط المستخدمين على النظام للكشف عن أي أنشطة غير مصرح به.

1.10.1.3 ما بعد حذف الحسابات:

- 1- حذف الحسابات: حذف حسابات المستخدمين الذين يتكون العمل بشكل نهائي.
- 2- أرشفة البيانات: أرشفة بيانات المستخدمين المحذوفين للاحتفاظ بها لفترة محددة.
- 3- إلغاء الوصول: التأكد من إلغاء جميع أنواع الوصول إلى النظام بعد حذف الحساب.

1.10.2 اختبار الأنظمة:

يتم اختبار الأنظمة بشكل نصف سنوي من قبل مختبر اختراقات أنظمة خارجي للأنظمة الموجودة داخل الشركة، تغطي الجوانب التالية:

الرقم	اسم الاختبار	العملية
1	اختبار الاختراق (Penetration Testing)	محاكاة هجوم حقيقي على النظام لاختبار مدى قدرة النظام على صد الهجمات وذلك عن طريق محاولة الوصول غير المصرح به إلى النظام لتحديد الثغرات التي قد توجد.
2	اختبار الثغرات (Vulnerability Testing)	اكتشاف الثغرات الأمنية في النظام باستخدام أدوات برمجية متخصصة لتحديد نقاط الضعف في النظام التي قد يتسلل منها المهاجمون.
3	الاختبار على مستوى الشبكة (Network Testing)	فحص الشبكة لاكتشاف أي تهديدات أو ثغرات قد تؤثر على أمان الاتصال.
4	التصيد الاحتمالي (Phishing Testing)	محاكاة محاولات الهجوم التي تستهدف الموظفين أو المستخدمين للوصول إلى معلومات حساسة.
5	اختبار مقاومة الأنظمة ضد هجمات البرمجيات الخبيثة (Malware Testing)	اختبار الأنظمة للكشف عن قدرتها في التعامل مع البرمجيات الخبيثة مثل الفيروسات.
6	اختبار الأمان على مستوى الأجهزة (Hardware Security Testing)	اختبار الأجهزة مثل الخوادم، نقاط الوصول، أجهزة التوجيه، والمعدات الأخرى للكشف عن الثغرات في مكونات الأجهزة.
7	اختبار الاستجابة للحوادث (Incident Response Testing)	محاكاة هجوم سيبراني لمعرفة مدى جاهزية النظام للاستجابة بشكل صحيح وفعال. يشمل ذلك معرفة كيفية التعامل مع الحوادث وتوثيقها.

1.10.3 الاستجابة للحوادث:

يقصد بالحوادث انتهاك سياسة الاستخدام أو ممارسات الأمان التي تعرض سرية المعلومات والعمليات في خطر، مثل:

إدارة الجودة والتطوير

Quality & Development Management

إدارة الجودة والتطوير

- محاولات الوصول غير المصرح به إلى المعلومات.

- الاستخدام غير المصرح به للمعلومات.

- التعديل غير المصرح به للمعلومات.

- فقدان المعلومات السرية والمحمية.

إدارة الجودة والتطوير

Quality & Development Management

إدارة الجودة والتطوير

1.10.3.1 آلية الاستجابة للحوادث:

فيما يلي الخطوات المتبعة للتعامل مع الحوادث:

الرقم	اسم العملية	وصف العملية
1	التحضير	إنشاء فريق الاستجابة للحوادث وتحديد الخدمات والأدوات اللازمة
2	تحديد الحدث	تحديد نطاق التأثير ومدى الضرر الناجم عن الحادث وإبلاغ الأطراف المعنية
3	احتواء الحدث	الخطوات المتبعة لعدم انتشار نطاق الحادث لتقليل الأضرار الناجمة عنه وعزلها، مثل: إجراء نسخ احتياطي للنظام للحفاظ على الحالة الحالية للنظام وتغيير كلمات المرور للأنظمة المتأثرة.
4	الإستئصال	إزالة جميع مكونات وأعراض الحادث والتحقق من عدم تكرار الحادث، مثل: استخدام مجموعات أدوات إدارية منفصلة للتحقق من النظام، إعادة تثبيت نظام تشغيل جديد وتقوية نظام التشغيل (تطبيق التصحيحات، تعطيل الخدمات غير الضرورية، تثبيت برنامج مكافحة الفيروسات)
5	الاسترداد	الخطوات المطلوبة لاستعادة البيانات والأنظمة إلى حالة عملها الصحيحة للسماح بعودة العمليات الأساسية، مثل: استعادة بيانات النظام باستخدام نسخة احتياطية جديدة ووضع الأنظمة المتأثرة تحت المراقبة الشبكية لمحاولات غير مصرح بها في المستقبل
6	الدروس المستفادة	تحليل مابعد الحادث للأنظمة التي تأثرت والأنظمة الأخرى المعرضة للخطر وتقديم تقرير مفصل لها للإدارة.

إدارة الجودة والتطوير

Quality & Development Management

إدارة الجودة والتطوير

Quality & Development Management



1.11 تفويض الصلاحية:

تفويض الصلاحية يسعى لتحسين فعالية القرارات الإدارية عبر توضيح الحدود والمسؤوليات، مما يساهم في سلامة العمليات، سوف يتم مراجعة مصفوفة تفويض الصلاحيات من قبل مشرف إدارة تقنية المعلومات وتعتمد من الرئيس التنفيذي سنوياً.

Quality & Development Management

Quality & Development Management

التعريفات والمصطلحات

الوصف	نوع الصلاحية	
الشخص الذي لديه مسؤولية نهائية وينفذ نشاطاً أو يقوم بالعمل (يقود مهمة أو نشاطاً معيناً).	مسؤول Responsible	R
مسؤول نهائي ومسؤول عن الموافقة وتقديم الضوء الأخضر النهائي بشأن المستند أو النشاط أو المهمة، بعد المراجعة والتأكيد على أن المستند أو النشاط أو المهمة قد تم إعدادها / إجرائها وفقاً لسياسات وعمليات وإجراءات المنظمة، واجتاز عملية المراجعة المطلوبة للمستند أو النشاط أو المهمة.	اعتماد Accountable/Approval	A
يأتي في اتصال ثنائي الاتجاه لغرض المراجعة والتوصية للموافقة، أو عرض اقتراح عام على عملية أو نشاط أو معاملة، وليس لديه سلطة اتخاذ القرار.	الاستشارة Consulted	C
الإشعار/الإبلاغ هو الطريقة الوحيدة للتواصل. هذا الشخص الذي يتم إبلاغه بنتيجة القرار دون الحاجة إلى اتخاذ قرار داخلي.	الإشعار Informed	I

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management



إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

تعريف المسميات الوظيفية

الرمز	المسمى الوظيفي
CEO	الرئيس التنفيذي Chief Executive Officer
LCM	مدير الشؤون القانونية والامتثال Legal and Compliance Manager
ITS	مشرف تقنية المعلومات Information Technology Manager
QDM	مدير إدارة الجودة والتطوير Quality and Development Manager



ملاحظات	QDM	LCM	ITS	CEO	بند الصلاحية
	I	I	R	A	اعتماد سياسات قسم الأمن السيبراني
	C	I	A	I	اقتراح التعديل على السياسات
	R	I	R	I	مراجعة التعديلات على السياسات
	I	I	R	A	اعتماد التعديلات على السياسات
	I	I	R	A	اعتماد إجراءات قسم الأمن السيبراني
	C	I	A	I	اقتراح التعديلات على الإجراءات
	R	I	R	I	مراجعة التعديلات على الإجراءات
	I	I	R	A	اعتماد التعديلات على الإجراءات

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

2 التقارير الداخلية

2.1 الخلفية:

يعمل مسؤول الأمن السيبراني على إعداد تقارير دورية تغطي الجوانب التالية

2.2 العملية:

الرقم	اسم التقرير	العملية	اجمالي الفترة الزمنية (بالأيام)	المسؤولية	إشارة المستند
1	تقرير مكافحة الفيروسات ESET	برنامج حماية يقوم باكتشاف وحظر وإزالة الفيروسات والبرامج الضارة.	يوميًا	مسؤول الأمن السيبراني	مشرف تقنية المعلومات
2	تقرير الحوادث الإلكترونية	تقرير يتضمن تفاصيل الهجمة أو الحادث الإلكتروني بما في ذلك وقت حدوثه وكيف حدث واثره ونطاق الاختراق.	يوميًا	مسؤول الأمن السيبراني	مشرف تقنية المعلومات
3	تقرير التقييم الذاتي	قياس مدى حوكمة الأمن السيبراني في الشركة.	كل 360 يوم	مسؤول الأمن السيبراني	إدارة الالتزام والامتثال



3 اللوائح السارية

يجب قراءة إجراءات التشغيل القياسية بالتماشي مع القوانين واللوائح والتعاميم الصادرة من هيئة التأمين والجهات المنظمة الأخرى والتي قد تشكل أو لا تشكل جزءاً من إجراءات التشغيل القياسية هذه والجدول التالي.

يجب أيضاً مراعاة التامة لأي قانون أو لائحة أو تعميم جديد أو محدث صادر من هيئة التأمين والجهات المنظمة الأخرى بعد تاريخ اعتماد إجراءات التشغيل القياسية هذه.

الرقم	اسم اللائحة/ التعميم	الجهة المنظمة	تاريخ الاصدار
1	لائحة وسطاء التأمين	هيئة التأمين	أكتوبر 2011
2	اللوائح التنفيذية لقانون مراقبة شركات التأمين التعاوني	هيئة التأمين	ابريل 2004
3	لائحة ادارة المخاطر	هيئة التأمين	ديسمبر 2008
4	لائحة مكافحة الاحتيال	هيئة التأمين	ديسمبر 2008
5	لائحة سلوكيات سوق التأمين	هيئة التأمين	اغسطس 2008
6	الدليل التنظيمي لأمن المعلومات	هيئة التأمين	مايو 2022
7	مبادئ تحليل التهديدات السيبرانية للقطاع المالي	هيئة التأمين	ابريل 2022
8	التأكيد على الإلتزام بالتعليمات الخاصة بحماية البيانات الشخصية للعملاء	البنك المركزي	جمادي الأول 1445
9	حماية البيانات الشخصية والسياسات والضوابط والقواعد الصادرة لحوكمة البيانات	البنك المركزي	جمادي الأول 1443

4 التوظيف والتدريب

تحدد ميزانية كل بداية سنة من الشركة يتم فيها رفع طلب لإدارة الموارد البشرية بعدد الموظفين المطلوبين في كل ربع من السنة حسب الميزانية المحددة والشواغل المتوفرة.

الإدارات الأخرى	قسم الأمن السيبراني	
1- يتم تدريب الإدارات الأخرى عن طريق توعيتهم بالهجمات السيبرانية وتحذيرهم عبر البريد الإلكتروني بالآتي: - استخدام كلمات مرور قوية: بحيث تكون طويلة ومعقدة وتجنب كلمات المرور سهلة التخمين. - تحديث البرامج بانتظام: بحيث يمنع استغلال الثغرات الأمنية التي يمكن أن يستغلها المهاجمون. - التحذير من رسائل البريد الإلكتروني المشبوهة: بحيث يتم فيها تجنب فتح رسائل البريد الإلكتروني والروابط المشبوهة التي قد تحتوي على برامج ضارة.	1- إدارة الموارد البشرية: إضافة الموظف الى نظام الموارد البشرية وتسليم العهدة له والتوقيع عليها. 2- إدارة تقنية المعلومات: - طلب وتجهيز الأجهزة اللازمة (مثل اللابتوبات، الشاشات، الهواتف) - إنشاء الحسابات الخاصة بالشركة (مثل البريد الإلكتروني، الرسائل الداخلية، أدوات الإنتاجية) - مساعدة الموظفين الجدد في إعداد أجهزتهم وحساباتهم - تقديم تدريب مبدئي عن كيفية استخدام أنظمة وأدوات الشركة - تقديم الدعم الفني المستمر والتدريب الإضافي عند الحاجة - التأكد من أن الموظفين الجدد يفهمون ويلتزمون بسياسات الأمن الخاصة بالأمن السيبراني	الموظف الجديد
-	1- الموارد البشرية: اشعار مشرف تقنية المعلومات بمغادرة الموظف أو تغيير دوره قبل اسبوعين على الأقل من تاريخ مغادرته. 2- إدارة تقنية المعلومات: يقوم مشرف الإدارة بالاجتماع مع الموظف ليطمئنه فيه مناقشة آلية تسليم الأعمال المكلفة. بدوره يقوم الموظف بتسليم وثيقة مفصلة للمشرف توضح المشاريع والمهام والمسؤوليات الجارية المكلف بها. بعد اتمام جميع المهام والمشاريع المكلف بها يتم اتخاذ الإجراءات التالية في آخر يوم للموظف: 1- إدارة الموارد البشرية: حذف الموظف من نظام الموارد البشرية واستلام العهدة منه والتوقيع عليها. 2- إدارة تقنية المعلومات: تسليم الموظف بطاقة الموظف وحذفه من نظام البصمة وتعطيل صلاحياته في الوصول إلى جميع الأنظمة والتطبيقات. - تحديث قوائم الوصول ومجموعات الأمان لإزالة وصول الموظفين المغادرين. - جرد جميع أصول تقنية المعلومات المسترجعة ومسح البيانات على الأجهزة المسترجعة لضمان عدم ترك معلومات حساسة.	الموظف المغادر

5 حفظ السجلات

فيما يلي عملية حفظ السجلات:

5.1 السجلات الإلكترونية:

تتم أرشفة السجلات و أخذ نسخ احتياطي للبيانات بشكل منتظم حتى يتم استعادتها في حالة فقدانها أو تلفها. حيث تتم الأرشفة عن طريق جهاز (NAS (Network-attached storage وهو نظام تخزين مركزي يقوم بتخزين البيانات وعمل نسخ احتياطي لها عن طريق الإتصال بالشبكة بحيث يسمح للمتصلين بالشبكة من أجهزة متعددة بتخزين بياناتهم وأرشفتها.

الرقم	العملية	وصف العملية
1	إدارة الوصول إلى البيانات	يتم الوصول إلى البيانات من أي جهاز أو شبكة على الإنترنت
2	النسخ الاحتياطي	يدعم النسخ الاحتياطي التلقائي
3	الأمان	يمكن تشفير البيانات وتحديد الأذونات
4	التكلفة	تكلفة لمرة واحدة وتكاليف الصيانة
5	المرونة	يمكن إضافة محركات أقراص إضافية إلى جهاز NAS لزيادة سعة التخزين دون الحاجة لاستبدال الجهاز بالكامل.

5.1.1 استعادة المعلومات أو نقلها من جهاز لآخر:

يتم استعادة المعلومات الموجودة في الأجهزة ونقلها من جهاز لآخر عن طريق عملية النسخ الاحتياطي الموجودة في جهاز NAS.

5.1.2 خطة الطوارئ لتجنب فشل عملية النسخ الاحتياطي :

يوفر جهاز NAS آلية لحماية البيانات من خلال التخزين المكرر (RAID) وهي طريقة لتخزين نفس البيانات في أماكن مختلفة على أقراص صلبة متعددة أو محركات أقراص ذات حالة صلبة لحماية البيانات في حالة فشل محرك الأقراص لضمان عدم فقدان البيانات في حال حدوث مشاكل مع الأقراص الصلبة.

6 المراجع:

رقم	المراجع
1	استراتيجية الأمن السيبراني
2	سياسات وإجراءات الأمن السيبراني
3	أدوار ومسؤوليات الأمن السيبراني
4	منهجية إدارة مخاطر الأمن السيبراني
5	برنامج التوعية والتدريب على الأمن السيبراني
6	سياسة الأمن السيبراني في مشاريع تقنية المعلومات
7	سياسة الامتثال التنظيمي للأمن السيبراني
8	سياسة التقييم والتدقيق الدوري للأمن السيبراني
9	سياسة الأمن السيبراني في الموارد البشرية
10	سياسات ومعايير إدارة الأصول والاستخدام المقبول للأصول
11	سياسة ومعايير إدارة الهوية والوصول
12	سياسة حماية أنظمة المعلومات ومرافق المعالجة
13	سياسة ومعايير حماية البريد الإلكتروني
14	سياسة ومعايير إدارة أمن الشبكات
15	سياسة ومعايير أمن الخوادم
16	سياسة ومعايير إدارة التحديثات الأمنية
17	سياسة ومعايير أمن الأجهزة المحمولة
18	سياسة ومعايير حماية البيانات والمعلومات
19	سياسة ومعايير التشفير
20	سياسة ومعايير أمن قواعد البيانات
21	سياسة ومعايير إدارة النسخ الاحتياطي والاستعادة
22	سياسة ومعايير إدارة الثغرات الأمنية
23	سياسة ومعايير اختبار الاختراق



24	سياسة ومعيار إدارة سجلات الأحداث والمراقبة للأمن السيبراني
25	سياسة ومعيار إدارة الحوادث والتهديدات السيبرانية
26	سياسة ومعيار أمن مكافحة البرمجيات الضارة
27	سياسة ومعيار الأمن المادي
28	سياسة ومعيار أمن تطبيقات الويب
29	سياسة إدارة استمرارية الأعمال في الجوانب المتعلقة بالمرونة السيبرانية
30	سياسة الأمن السيبراني لمقدمي الخدمات الخارجيين
31	سياسة الأمن السيبراني للحوسبة السحابية والاستضافة

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

